SECURITY EXCEPTION REQUEST

WyIT 3002

PURPOSE: To provide a method of documenting a security exception request that deviates from state enterprise best practice methodologies.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

IV. REQUIREMENTS

An exception to a published IT/information security policy, standard, or practice may be granted by the CIO in any of the following situations:

- A temporary exception where immediate compliance would disrupt critical operations.
- A legacy system is retiring, and compliance is not possible (risk must be managed).
- A long-term exception where compliance would adversely impact the State of

Wyoming business.

- Where compliance would cause a major adverse financial impact that would not be offset by the reduced risk occasioned by compliance (i.e., the cost to comply offsets the risk of non-compliance).

V. TERM OF REQUESTS

- Exceptions are reviewed on a case-by-case basis and approval is not automatic.
- Granted exceptions will not exceed one year.
- Extensions may be requested upon expiration.

A determination regarding any requested exception request will be provided by the CIO as soon as reasonably possible. More complex requests may receive a determination that further investigation is necessary. The CIO will evaluate exception requests on a case-by-case basis, accounting for the level of risk, potential threats and vulnerabilities, and operational and technical limitations or constraints. Additional stakeholders and subject matter experts may be included during the evaluation process, but the CIO will have final responsibility and accountability for approving or denying a request for an exception. The CIO may grant an exception while working with the requestor to establish a timeline for full compliance. Exceptions are valid for the agreed-upon timeline but will not exceed one year. If there is a continuing need for an exception, the requestor must request an extension to the exception at least 30 days prior to its expiration. If there is a pattern of requested exceptions for a particular solution, the CIO and/or CIO may recommend alternative solutions.

VI. REQUIRED INFORMATION

Exception requests must be submitted on a completed Exception Request Form and include:

- The name and contact information of the agency Director making the request. (all requests must be submitted by an agency Director or designee).
- A description of the technology, process, and standard the exception is being requested for.
- A detailed description of the specific device, application, or service the exception is being requested for.

- The alternative security solution proposed as part of the request.
- The type of data affected, directly or indirectly, and any statute or compliance related to the request.
- The business impact if this request were denied.
- Acknowledgment that the agency Director considered and fully understood the associated internal and external risks required to support the request.
- Acknowledgment that the agency Director accepts the risks associated with the request.

VII. REVOKING REQUESTS

The exception request process is intended to be a generic method applying to all IT information security policies and standards. Exception requests may be revoked in the event of a security incident or policy violation using established incident response procedures.

REFERENCES: This policy has no supporting references to websites, other policies, or federal or state statutes.

Review/Approval:

Date Issued/Review Date

This policy shall be reviewed at least annually and updated / reviewed / approved as defined in the Office of Chief Information Officer (OCIO) Policy lifecycle.

Factors that may trigger an out of cycle review are:

- Significant changes in administrative, legal, or regulatory requirements;
- Results of cybersecurity incidents or operational audits;
- Findings from compliance reviews or gap assessments;
- Changes in State or Federal policies impacting audit logging obligations; or
- Introduction of new technologies or retirement of existing systems that impact audit requirements.

The review and update process shall be coordinated by Governance, Risk and Compliance (GRC), completed by the policy owner and approved through the OCIO policy review workflow.

Approval

This policy must be signed by the appropriate officer (listed below) before it is considered approved and put into force.

The review and update process shall be coordinated by the GRC team, completed by the policy owner and approved through the OCIO policy review workflow.

Jeff Clines	Director
Officer Name	Officer Title
_____	_____
Officer's Signature	Date

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	05/10/2024 - 05/24/2024	June 2024

REVISIONS			
REVISION DATE	**REVISED BY**	**SUMMARY OF REVISIONS**	**LAST APPROVED BY**
07/15/2026	ETS Governance, Risk and Compliance	Updated link(s) to the Security Exception Request Form to reflect a change in process.	June 2024

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**